

Section 07

Industrial Security (Bachelor)



Section 07 – Risk Management

Risk Management

Lecture Notes

Department of Computer Science

1 Risk Fundamentals

2 Methodologies

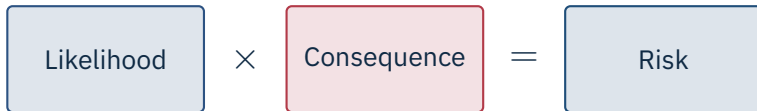
By the end of this section you will be able to

- Construct and interpret a qualitative risk matrix for an industrial site.
- Apply Cyber-HAZOP / Cyber-PHA techniques.
- Distinguish IT risk from safety risk.
- Recognise the Consequence-Driven Cyber-Informed Engineering (CCE) approach.

1

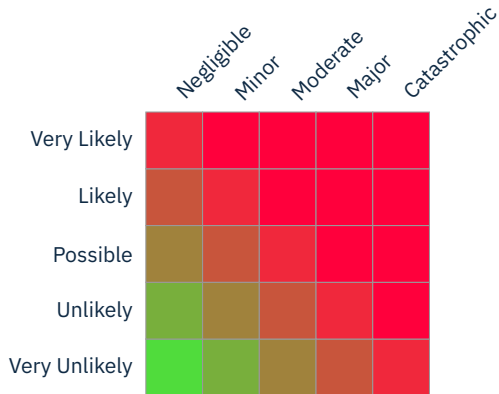
Risk Fundamentals

Section 07 – Risk Management



Consequence dimensions

Safety, environment, production loss, reputation, regulatory.
Likelihood depends on adversary capability *and* exploit difficulty.

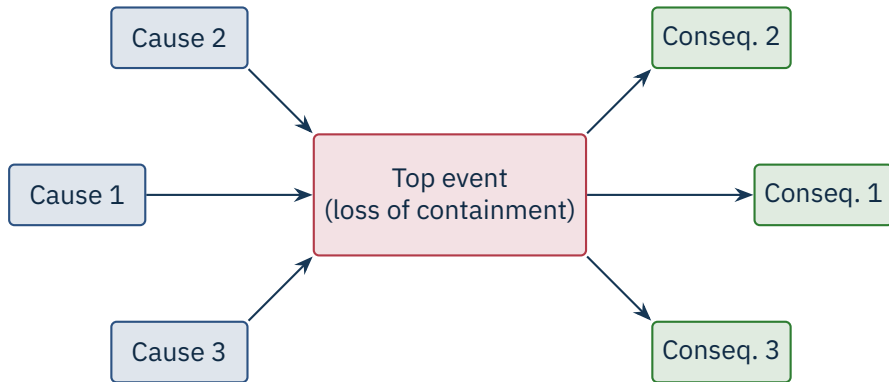


Useful for quick communication; risk of false precision and gaming.

2

Methodologies

Section 07 – Risk Management



Barriers on the left prevent causes; barriers on the right mitigate consequences.

No

More

Less

Reverse

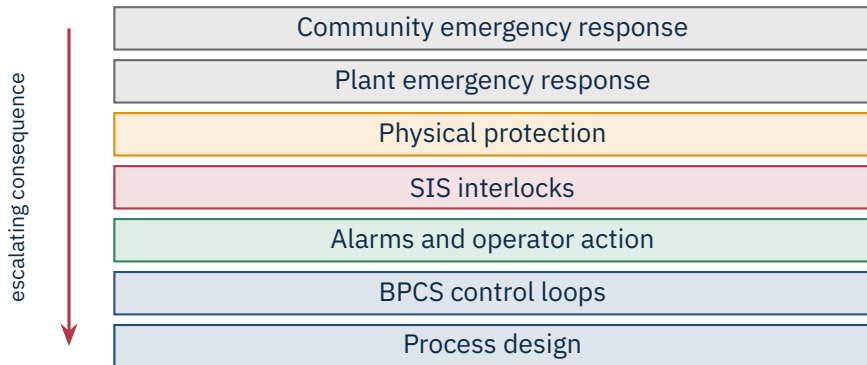
As well as

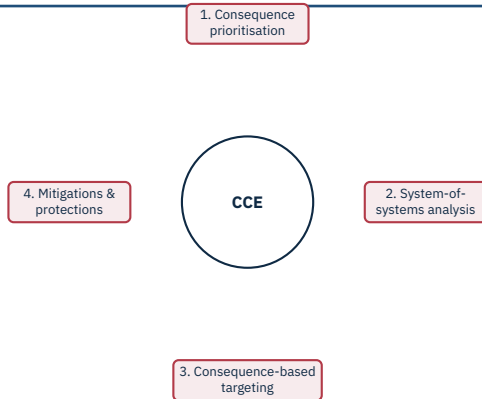
For each node, ask:

“What if an **attacker** caused the deviation *[guide word]* *[parameter]*?”

Examples: no flow → attacker closes inlet valve; high pressure → attacker disables relief actuator.

Source: IEC 61882:2016 (HAZOP) | ISA TR84.00.09 (Cybersecurity for SIS).





INL methodology

“What would I do if I were the adversary?” Engineer out the worst consequences.

Source: A. Bochman, S. Freeman, *Countering Cyber Sabotage*, INL/CRC Press, 2021.

Avoid

remove function

Mitigate

reduce L or C

Transfer

insure / contract

Accept

signed-off

Acceptance is legitimate

But it must be reviewed periodically – threats evolve.

Loss event frequency

×

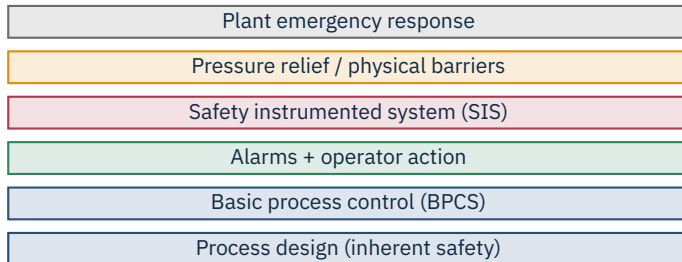
Loss magnitude

= Annualised loss expectancy (ALE)

When FAIR earns its keep

When the board asks “how much does this risk actually cost us?” – and a heat-map is no longer enough.

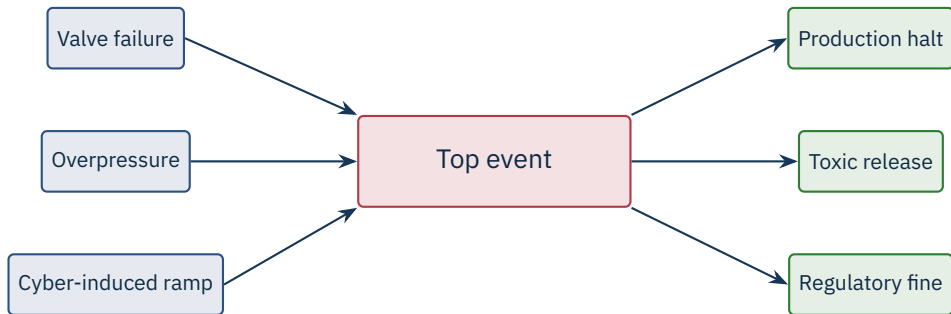
Source: The Open Group, Risk Analysis (O-RA) Standard (FAIR), C20A:2021 | J. Jones & J. Freund, Measuring and Managing Information Risk, 2014.



Independence is the value

Each layer must be *independent of the next* – otherwise one common-cause failure removes them all.

Source: CCPS, Layer of Protection Analysis: Simplified Process Risk Assessment, AIChE, 2001.



Barriers on the left prevent causes; barriers on the right mitigate consequences.

	Qualitative	Quantitative
Speed	Hours	Days to weeks
Data needed	Workshop + expert judgement	Frequency & impact data
Output	Heat map / risk matrix	Loss curve in money
Use cases	Initial triage	Board / insurance / capex
Pitfalls	False precision	Garbage in $\Rightarrow$ garbage out

- First-party: forensics, IR retainer, business interruption.
- Third-party: liability, regulator response.
- Typical exclusions: nation-state acts of war, unpatched known CVEs, missing MFA.
- Insurers now drive a minimum control baseline (MFA, EDR, backups).

Caution

Backstop, not a control Insurance is a backstop. Premiums rise sharply if your baseline is weak, and “act of war” exclusions are tested in court each year.

Source: Munich Re Cyber Insurance Risk Snapshot, 2024 | Merck v. Ace American (NotPetya war-exclusion ruling), New Jersey Appellate, 2022.

- **Ransomware on Historian** – Likely / Major / **H**: immutable backups, EDR.
- **SIS reprogrammed by attacker** – Unlikely / Catastrophic / **H**: key-switch + signed downloads.
- **Vendor account abuse** – Possible / Major / **H**: MFA, brokered remote access, session recording.
- **USB-borne malware** – Likely / Moderate / **M**: USB allow-listing, kiosk scanner.
- **PLC firmware CVE** – Possible / Major / **M**: vendor patch in maintenance window; virtual patch on IPS meanwhile.

★ Key Takeaway: What to remember from this section

- Industrial risk has dimensions IT does not: safety, environment, regulatory.
- Cyber-HAZOP integrates security into the language of process safety teams.
- LOPA reminds us that several independent layers must fail for a disaster.
- CCE asks: how would the adversary win? – and re-engineers to remove the winning move.

- The Open Group. *Risk Analysis (O-RA) Standard*, C20A, 2021 (FAIR).
- Jones, J., Freund, J. *Measuring and Managing Information Risk: A FAIR Approach*, Butterworth-Heinemann, 2014.
- Center for Chemical Process Safety (CCPS). *Layer of Protection Analysis: Simplified Process Risk Assessment*, AIChE, 2001.
- IEC 61882:2016. *Hazard and operability studies (HAZOP studies) – Application guide*.
- ISA-TR84.00.09:2017. *Cybersecurity related to the Functional Safety Lifecycle*.
- Bochman, A., Freeman, S. *Countering Cyber Sabotage: Introducing Consequence-Driven, Cyber-Informed Engineering (CCE)*, INL/CRC Press, 2021.
- IEC 62443-3-2:2020. *Security risk assessment for system design*.
- NIST SP 800-30 Rev. 1. *Guide for Conducting Risk Assessments*, 2012.
- ISO 31000:2018. *Risk management – Guidelines*.

End of Section 07



Risk Management

Questions and discussion